M365-02 · Exchange Online Mailbox Standard

Mailbox sizing, retention, forwarding, rules and delegation — stated once, for everyone with a mailbox.

Field	Value
Document ID	M365-02
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 2 — Advanced Technical Services.
Review cycle	Annually.
Governing policy	Your organization's email and account policy. That policy governs; this standard is the operational detail beneath it and must not contradict it.

1. Purpose

Most organizations have an email and account policy, and it governs. This standard is the operational layer underneath: the numbers, the defaults, and the handful of rules that IT applies consistently.

2. What every mailbox gets

	Staff	Contractor / guest	Shared / resource
Mailbox size	Per licence (M365-20)	Per licence	Per licence
Archive	Enabled	Enabled	Enabled where needed
Retention	Per M365-16	Per M365-16	Per M365-16
Litigation hold	Applied where required (M365-16)	As required	As required
External forwarding	Blocked (§3)	Blocked (§3)	Blocked
Automatic replies	Self-service	Self-service	Set by the owner
Delegation	By request (§5)	Not routinely	Membership, not delegation (M365-03)

3. External forwarding — the one hard rule

> **Automatic forwarding of work mail to an external address is blocked, for everybody.**
> This is the single most valuable mailbox control the organization can operate, and it is worth the small amount of annoyance it causes.
>
> Two reasons. First, it is the standard exfiltration mechanism after an account compromise: an attacker sets a forwarding rule and reads everything thereafter without signing in again, which is invisible to the account holder and survives a password reset. Second, work correspondence forwarded to a personal account is outside every retention, discovery and security control the organization operates — and it is frequently correspondence about other people.
>
> Manual forwarding of an individual message remains available. That is a person making a decision about a specific message, which is a different thing entirely.

Where a genuine business need exists — a shared function forwarding to a monitored departmental address inside the tenant — that is internal forwarding and is fine. External forwarding exceptions require Tier 4 approval, a stated reason, and an expiry, and should be very rare.

4. Rules and automatic processing

- Users may create their own inbox rules for filing and organisation. That is ordinary use and needs no involvement from IT.
- Rules that delete, or that move mail out of the mailbox, are the attacker's pattern (M365-22 §5). IT reports on newly-created rules of that shape and follows up — not to police filing habits, but because a rule the user did not create is a compromise indicator.
- When investigating a suspected compromise, checking for attacker-created rules is mandatory and is the step most often missed.
- Automatic replies should say when the person is back and who to contact meanwhile. An out-of-office giving neither is a small daily cost across the whole organization.

5. Delegation and shared access

Mechanism	Use when
Delegate access	One person manages another's mail or calendar — an assistant, or cover during leave. Personal and revocable (ACC-14).
Shared mailbox membership	Several people answer mail to a departmental address. This is the right answer far more often than delegation (M365-03).
Send-as	Mail should appear to come from the department rather than the individual.
Calendar sharing	Availability visible to colleagues. Default is free/busy; detail by choice.
Full mailbox access granted by IT without the owner's knowledge	Never, except under GOV-03 or a Tier 4 decision with a recorded reason.

6. Sending limits and moderation

- Platform recipient and rate limits apply and are not adjustable. Where somebody hits them, the answer is usually that they should be using M365-06 rather than sending manually.
- Whole-population groups are moderated (M365-04 §8). One misdirected reply-all to the whole organization is a genuinely bad afternoon.
- Bulk sending for legitimate organization communication goes through the approved mechanism, not through a personal mailbox.

7. Retention and archiving

- Retention policy is applied at tenant level per M365-16, not chosen per mailbox.
- The archive is part of the mailbox, not a backup. Deleting from the archive deletes it.
- On separation, mailbox content is retained a minimum of two years with no maximum (ACC-01 §7.3). Confirm that Teams chat retention meets the same floor, or the floor is defeated for one content type.
- Individual users do not need to manage retention. Where somebody asks how long their mail is kept, the answer is in M365-16 and it should be a published answer rather than a per-question one.

8. Mailboxes that are not people

Type	Governed by
Shared mailbox for a department or function	M365-03. Named owner, membership, review.
Room and equipment mailboxes	Booking policy set by the room's owning department; IT provisions.
Service or application mailbox	ACC-08. Must have a human owner recorded.
A mailbox for a departed person	Converted to shared or retained inactive per ACC-01 §7.3. Never left as a live licensed account with somebody else reading it.

9. Service levels

Request	Commitment (per GOV-06)
Mailbox questions	Answered at Tier 1 from Appendix A.
Delegation setup	P3 — 1 coverage day, with the mailbox owner's consent.
External forwarding exception	P3 to Tier 4. Expect it to be declined with an alternative.
Suspicious rule detected on a mailbox	P2 — investigated same coverage day (M365-22).
Mailbox full	P3 — archive and licence checked (M365-20) before anything else.

10. Records

Record	Held in	Retention
External forwarding exceptions, with reason and expiry	Tier 4 record	3 years
Delegation grants, with owner consent	Ticket	3 years
Full mailbox access granted without owner knowledge	Tier 4 / incident record	7 years
Suspicious rule investigations	Ticket + security record	3 years

11. Related documents

ID	Title	Relationship
Email Policy	Your email and account policy	Governs. This standard sits beneath it.
M365-01	Microsoft 365 Service Description	What a mailbox is, at service level.
M365-03	Shared Mailbox Request & Ownership	§8, and the better answer to most delegation requests.
M365-05	Email Alias & Address Change Standard	Addresses and aliases.
M365-06	Mass Communication & Broadcast Email Approval	§6.
M365-16	Retention, Legal Hold & eDiscovery	§7.
M365-22	Phishing Reporting & Email Threat Response	§3 and §4 — the attacker patterns.
ACC-14	Mailbox & Calendar Delegation Standard	The detail behind §5.
ACC-01	Account Lifecycle	§7.3 retention, and mailbox disposition at separation.
M365-20	License Assignment & Reclamation	Mailbox size follows the licence.

Appendix A — Desk card

	They ask	You say
1	“Can I forward my work mail to Gmail?”	No — external forwarding is blocked for everyone. You can forward individual messages by hand. If it is a workload problem, a shared mailbox may be the answer.
2	“My mailbox is full”	Check the archive is enabled and the licence is right before anything else.
3	“Can somebody manage my calendar?”	Yes — delegation. We need your consent on the ticket.
4	“Several of us need to answer this address”	That is a shared mailbox, not delegation (M365-03). It needs a named owner.

	They ask	You say
5	“How long is my email kept?”	Per the retention policy — M365-16 has the published answer.
6	“There is a rule in my mailbox I did not create”	Stop. That is a compromise indicator. M365-22 §5, same day.
7	“I need to email everyone”	M365-06. Through the office that owns that population.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.